

Task - 13: Secure API Testing & Authorization Validation

Internship Task – Elevate Labs

This task focused on understanding REST API security and validating authentication and authorization controls. The objective was to test APIs for common security misconfigurations and identify authorization flaws.

1. Introduction to API Security

APIs allow applications to communicate using HTTP methods such as GET, POST, PUT, and DELETE. Securing APIs is critical because they often expose sensitive business logic and data.

2. Understanding REST APIs

REST APIs use endpoints to perform operations. Each request includes headers, parameters, and a request body which must be properly validated.

3. API Configuration Using Postman

Postman was used to configure API endpoints by setting: - Endpoint URLs - Request headers - Authentication tokens - Request body data

This helped in testing API behavior under different conditions.

4. Testing API Authentication

Requests were sent with valid and invalid credentials. Responses were analyzed to confirm whether authentication controls were properly enforced.

5. Authorization Validation

Authentication headers were removed and requests were resent. Resource identifiers were modified to test for broken authorization vulnerabilities.

6. Input Validation Testing

Malformed and unexpected input values were sent to APIs. This helped identify improper input validation and error handling issues.

7. Rate Limiting Checks

Multiple rapid requests were sent to test if rate limiting was enforced. Lack of rate limiting can lead to brute-force and denial-of-service attacks.

8. Response Code Analysis

HTTP response codes and error messages were reviewed. Incorrect responses can reveal sensitive information to attackers.

9. Mapping to OWASP API Risks

Identified issues were mapped to OWASP API Security risks such as: - Broken Object Level Authorization - Excessive Data Exposure - Improper Authentication

Learning Outcome

Through this task, I gained practical experience in secure API testing. I learned how to identify authentication and authorization flaws and understand common API security risks.